future internet

IMPACT FACTOR 3.6

CITESCORE 8.3

Article

A Systematic Comparison Between Open- and Closed-Source Large Language Models in the Context of Generating GDPR-Compliant Data Categories for Processing Activity Records

Magdalena von Schwerin and Manfred Reichert

MDPI

https://doi.org/10.3390/fi16120459

future internet

MDPI

Article

A Systematic Comparison Between Open- and Closed-Source Large Language Models in the Context of Generating GDPR-Compliant Data Categories for Processing Activity Records

Magdalena von Schwerin * and Manfred Reichert

Institute of Databases and Information Systems, Ulm University, 89081 Ulm, Germany; manfred.reichert@uni-ulm.de
* Correspondence: magdalena.von-schwerin@uni-ulm.de

Abstract: This study investigates the capabilities of open-source Large Language Models (LLMs) in automating GDPR compliance documentation, specifically in generating data categories—types of personal data (e.g., names, email addresses)—for processing activity records, a document required by the General Data Protection Regulation (GDPR). By comparing four state-of-the-art open-source models with the closed-source GPT-4, we evaluate their performance using benchmarks tailored to GDPR tasks: a multiple-choice benchmark testing contextual knowledge (evaluated by accuracy and F1 score) and a generation benchmark evaluating structured data generation. In addition, we conduct four experiments using context-augmenting techniques such as few-shot prompting and Retrieval-Augmented Generation (RAG). We evaluate these on performance metrics such as latency, structure, grammar, validity, and contextual understanding. Our results show that open-source models, particularly Qwen2-7B, achieve performance comparable to GPT-4, demonstrating their potential as cost-effective and privacy-preserving alternatives. Context-augmenting techniques show mixed results, with RAG improving performance for known categories but struggling with categories not contained in the knowledge base. Open-source models excel at structured legal tasks, although challenges remain in handling ambiguous legal language and unstructured scenarios. These findings underscore the viability of open-source models for GDPR compliance, while highlighting the need for fine-tuning and improved context augmentation to address complex use cases.

Keywords: large language model; GDPR documentation; natural language processing

check for updates

Citation: von Schwerin, M.; Reichert, M. A Systematic Comparison Between Open- and Closed-Source Large Language Models in the Context of Generating GDPR-Compliant Data Categories for Processing Activity Records. *Future Internet* **2024**, *16*, 459. https://doi.org/10.3390/fi16120459

Academic Editor: Paolo Bellavista

Received: 18 October 2024
Revised: 1 December 2024
Accepted: 3 December 2024
Published: 5 December 2024

1. Introduction

The extensive capabilities of generative AI models, particularly Large Language Models (LLMs), offer numerous opportunities in areas such as content generation, machine translation, sentiment analysis, and customer service, particularly due to their ability to understand and produce text on a large scale [1]. A document-driven domain that relies on extensive text-based work, including contract drafting, research, and case analysis is the legal domain, whose reliance on repetitive text-heavy tasks makes it well suited for automation using LLMs [2].

The implementation of the General Data Protection Regulation (GDPR), enacted by the European Union in 2018 [3], has introduced repetitive and text-intensive tasks for organizations handling personal data. These tasks have significantly increased the demand for manual labor, creating an opportunity to explore the use of LLMs to streamline GDPR compliance tasks. In respect to the GDPR, organizations need to maintain extensive documentation, including records of processing activities, assessments for high-risk data processing, and records of consent when personal data are collected [3]. A key requirement is the detailed recording of processing activities, which involves documenting the types of data processed, the groups of data subjects involved, the purposes of the processing, and the retention periods (see Figure 1) [4].

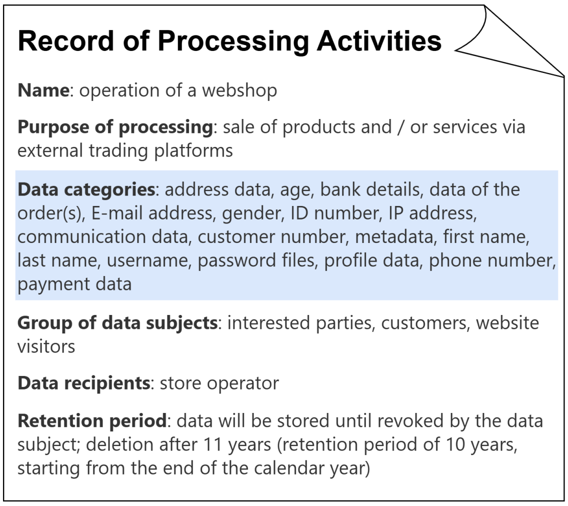

Figure 1. Report of a processing activity as required by the GDPR.

Given these extensive and precise documentation requirements, organizations face growing challenges in achieving efficiency and accuracy in GDPR compliance, making LLMs a promising tool to partially automate compliance tasks. However, leveraging LLMs for GDPR compliance introduces significant challenges. GDPR documentation often relies on precise interpretations of legal terms such as “necessary”, “appropriate”, or “adequate”, which are inherently ambiguous and context-dependent. This creates challenges for LLMs to generate legally valid text [2]. Additionally, the static knowledge bases of LLMs make it difficult for them to reflect real-time updates to the GDPR or evolving regulatory requirements [2]. This further complicates their application to compliance tasks. As LLMs have been designed to predict the most probable next token, they are prone to create hallucinated information [2], which can be particularly problematic when precision and adherence to strict legal standards are essential.

To be effective with respect to GDPR compliance, LLMs must meet strict requirements. These include ensuring data security, preserving privacy (Art. 32 GDPR [3]), providing transparency in data processing (Recital 58 GDPR [3]), and achieving high accuracy in generating compliance documentation. Furthermore, the GDPR mandates robust control over data handling (Art. 5, 24, 25, 32 GDPR [3]), which poses challenges for models hosted externally, as organizations cannot guarantee compliance if they lack insights into how the data are processed.

For these reasons, the choice between open-source and closed-source LLMs is critical. Closed-source models such as GPT-4, though being powerful, raise data security and compliance concerns due to their API-based access and lack of visibility into pretraining data. Open-source models, on the other hand, allow for on-premise deployment, giving organizations full control over their infrastructure and data, which is crucial to meet the strict standards set out in the GDPR. Comparing these approaches helps assess whether open-source models, despite their potentially lower out-of-the-box performance, can meet the dual requirements of compliance and efficiency for GDPR-specific tasks.

This study uses the generation of data categories for processing activity records by LLMs as a test case to evaluate their suitability for supporting GDPR compliance documentation. Despite general limitations with respect to law-specific language and real-time updates, the creation of data categories seems to be feasible as it relies on core GDPR definitions rather than evolving legal terms. In this study, we explore partial automation of drafting records of processing activities. If the quality of the generated data categories proves to be sufficient, this approach could be extended to automate the generation of other required attributes in these records.

This study evaluates whether open-source models, when combining them with context-specific techniques, can match or exceed the performance of GPT-4 while ensuring GDPR compliance. We develop experiments to assess the response quality of LLMs in generating data categories. These experiments compare the out-of-the-box performance of the models with results we obtain using context-augmenting techniques. These techniques include few-shot prompting [5] and Retrieval Augmented Generation (RAG) [6], which augment the models with closed-domain data to improve factual accuracy. Furthermore, we test the understanding of the task with two benchmarks. The generation benchmark uses five different prompts asking the LLM to generate data categories for a given processing activity, while the multiple choice benchmark asks the LLM to select the correct data categories for a given processing activity.

In particular, this research seeks to answer the following research questions:

- **Research Question (RQ1)**: Can open-source LLMs generate data categories for GDPR compliance documentation as effectively as GPT-4?
- **Research Question (RQ2)**: To what extent do context-augmenting techniques such as few-shot prompting and Retrieval Augmented Generation (RAG) enhance LLM performance in drafting documents for GDPR compliance?

This study systematically compares open-source and closed-source LLMs on a GDPR-specific task and explores the impact of advanced prompting and context-augmenting techniques. It aims to establish a framework for applying LLMs in regulated, text-intensive domains such as GDPR compliance.

The remainder of this paper is structured as follows: Section 2 reviews related work on LLMs in legal tasks and GDPR compliance. Section 3 details the methodology, including model selection, use case, and experimental setup. Section 4 presents the experimental results, followed by a discussion in Section 5. Finally, Section 6 concludes the study with key findings and implications.

2. Related Work

This section introduces the GDPR and explores the recent developments of LLMs in the legal domain, highlighting their potential and applications, along with the challenges and opportunities identified in related research.

2.1. The General Data Protection Regulation

The General Data Protection Regulation (GDPR) [3] was enacted on 25 May 2018 by the European Union (EU) to harmonize data privacy laws across the EU. The GDPR regulates by law when and under what conditions data may be collected from individuals, what they may be used for, and what rights the data subject to whom the data belong has.

The GDPR [3] is based on nine fundamental principles, which are summarized in Figure 2. These principles govern the lawful collection and processing of data. The first principle of *lawfulness*, *fairness*, *and transparency* requires that data processing has a legal basis. Moreover, fair data processing involves handling personal data reasonably, avoiding unjustified harm, and considering the impact on individuals and groups. Transparent processing requires clear and honest communication from the start, ensuring individuals can make informed decisions about the handling of their data, even when collected indirectly. *Purpose limitation* ensures that data are collected for specified, explicit, and lawful purposes and cannot be processed in a manner that violates these purposes. *Data minimization* ensures that personal data should be limited to what is relevant in the given context. The *accuracy* principle mandates that data should always be kept up to date, while *storage limitation* enforces that personal data are kept in minimal quantities and only for the duration of their genuine necessity or legal mandate. *Integrity and confidentiality* aim to guarantee the security of the processed data and to enforce the implementation of data security. The *accountability* principle makes the data controller responsible and, therefore, accountable for compliance with the GDPR. *Privacy by design* implies that privacy should be considered at every stage of product development. Finally, the default settings for online services should always minimize the processing of personal data, according to *privacy by default*.

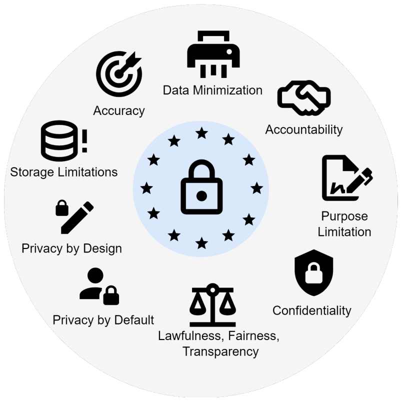

Figure 2. The principles of personal data protection as set in the GDPR.

The GDPR grants individual rights to data subjects (see Figure 3). Data subjects have the right to be informed about the processing of their data by authorities and organizations. The right to access allows data subjects to obtain a copy of their stored data, while the right to erasure defines the different circumstances under which the data subject can force the deletion of its data. This corresponds to the right to objection, which allows data subjects to stop the processing of their data. The right to restrict processing allows data subjects to request that their data be restricted or suppressed. In addition, the right to rectification allows data subjects to have their data corrected or completed. Finally, the GDPR grants data subjects the right to data portability, which means that personal data can be easily transferred from one IT system to another.

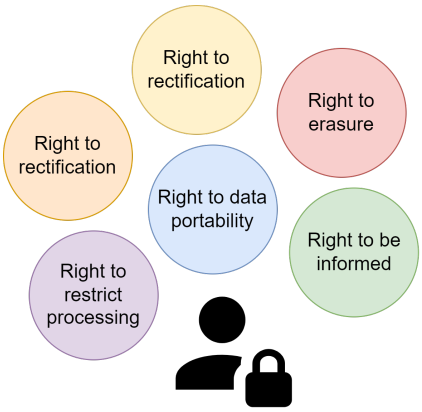

Figure 3. The rights of individuals concerning their personal data as set in the GDPR.

The principles and individual rights outlined above impose a responsibility on all those who access and process data to document their data protection measures and processing activities. This documentation consists of at least thirteen mandatory documents, which are defined in various articles of the GDPR. Key documents include the Personal Data Protection Policy, the Privacy Notice, the Employee Privacy Notice, the Data Retention Policy and Schedule, the Data Subject Consent Form, the Parental Consent Form, and the DPIA Register. Additionally, documents, such as the Supplier Data Processing Agreement, and various data breach responses and notification forms, are required.

With the stringent requirements of the GDPR, there is a growing need for tools to support regulatory compliance. Recent advancements in LLMs offer promising applications for complex legal tasks as needed for GDPR compliance. The next section explores research on tasks for LLMs in the legal domain.

2.2. LLMs in the Legal Domain

Current research has identified several key tasks for automation through an LLM in the legal domain [2]. The THIUR team [7] developed a specialized LLM for *legal case retrieval*. This task involves retrieving cases from a large legal database of historical cases similar to a specified query case. *Legal judgment prediction* aims to use LLMs to improve fair reasoning and efficiency in legal processes [2]. Furthermore, LLMs are trained for *legal question answering* to provide complex legal information to the general public in an understandable format. Significant contributions in this area include fine-tuned LLMs on legal Q&A datasets, such as Lawyer Llama [8] and Lawyer GPT [9]. However, while Lawyer Llama and Lawyer GPT demonstrate the potential for legal question answering, their fine-tuning on general legal Q&A datasets limits their ability to address highly specific tasks such as GDPR compliance. These models perform well in recalling legal knowledge, but might lack the structured output necessary to generate compliance documentation. Savelka et al. [10] evaluated LLMs for *semantic annotation*, demonstrating that GPT-4 performed well in labeling parts of legal documents such as contracts. However, the study primarily focused on the model's ability to categorize existing content, rather than its capacity to generate new content or adhere to regulatory requirements such as those outlined in the GDPR. This limits its applicability to compliance tasks, where precise generation and structured outputs are critical. *Document drafting* represents another labor-intensive legal task explored by Weller et al. [11]. The authors created a dataset to evaluate how effectively LLMs understood and executed detailed instructions in the drafting process. Their results showed that while LLMs performed well with complex tasks, they struggled with nuanced instructions requiring a deep contextual understanding. This limitation is particularly relevant for GDPR compliance, where generating structured domain-specific documentation requires not only linguistic accuracy, but also strict adherence to legal standards and terminologies. These challenges highlight a key gap in current research: *the ability of LLMs to generate outputs tailored to the structured requirements of legal and regulatory documents, an area that this study aims to address*.

This study investigates how effectively LLMs can support GDPR-specific drafting needs. There are currently no other studies on LLMs for drafting documents in the context of GDPR compliance. However, other application areas for LLMs in GDPR compliance have been explored in recent work. Azeem et al. [12] studied the completeness checking of Data Processing Agreements, a document required by the GDPR for international data transfers. They compared different LLMs on over 31,000 sentences, labeled to indicate whether each sentence complied with specific GDPR provisions. Here, LLMs performed well, achieving an F2 score of 89%. Although Azeem et al. provided promising results for completeness checking of Data Processing Agreements based on LLMs, their study did not address the generation of other critical GDPR compliance documents. Moreover, the reliance on pre-labeled datasets and on a static set of GDPR provisions limits the applicability of the models in evolving compliance contexts. The work presented in [13] assessed LLM compliance with the GDPR in a series of experiments using sensitive medical data. The results of that work demonstrated that LLMs were highly susceptible to retaining and copying sensitive personal information from their input. This suggests that locally hosted open-source models are crucial for the legal domain, so that no data can be processed further by third parties. These models ensure compliance with GDPR principles like data minimization and storage limitation (Art. 5 GDPR [3]) by maintaining full control over data processing. Furthermore, they mitigate the risks of unauthorized data retention, which is particularly critical for drafting compliance-sensitive documents. Nayak et al. [14] addressed data privacy concerns by proposing a named-entity tagging tool, which identified and labeled specific types of information (e.g., names, locations) to distinguish GDPR-compliant queries from non-compliant ones. The tool filtered queries before passing them to GPT, which was hosted in the US, ensuring GDPR compliance by ruling out unauthorized data retention. Montagna et al. [15] developed a GPT-based chatbot architecture for medical patient self-management. This chatbot used a gated personal data manager to store personal data obtained from interactions with the chatbot. This approach emphasized the importance of implementing mechanisms to control and restrict access to sensitive data, ensuring compliance with the principles of confidentiality and data integrity of the GDPR.

In summary, current research highlights gaps in LLM capabilities, particularly in generating structured, regulatory-compliant outputs essential for tasks such as GDPR documentation. These gaps underscore the need for specialized evaluation frameworks that assess LLMs on compliance-specific tasks. The next section details evaluation frameworks established for the legal domain in related research.

2.3. Evaluating LLMs in Legal Tasks

Due to the high complexity and accuracy requirements in the legal domain, a careful evaluation of LLMs on a wide range of legal tasks becomes essential. Recent advances in legal benchmarks, such as LawBench [16], LegalBench [17], and LAiW [18], have provided frameworks for assessing LLM performance on tasks such as legal knowledge recall and logical reasoning across different case types. LawBench and LAiW focus on general legal reasoning tasks, such as retrieving case law, applying legal principles, and assessing logical consistency across cases. These benchmarks are valuable for understanding how well LLMs perform when retrieving legal knowledge and reasoning about legal knowledge. However, they lack the specificity required for regulatory compliance tasks such as GDPR documentation. For example, GDPR compliance requires the creation of structured documents with precise formatting and terminology, i.e., requirements not assessed by these benchmarks. In addition, regulatory compliance requires sensitivity to evolving legal standards and a robust handling of sensitive data, whereas both aspects are not covered in current evaluation frameworks.

Another limitation of existing benchmarks is their emphasis on static datasets, which do not reflect the dynamic nature of legal and regulatory environments. For compliance-sensitive tasks, such as GDPR documentation, LLMs must generate outputs that conform to predefined legal standards while taking updates to the law into account as well. Current benchmarks do not assess the adaptability of the LLMs to such changes or their ability to manage jurisdiction-specific requirements, which are critical to ensuring legal accuracy and compliance.

In addition, current benchmarks do not evaluate the structured output generation required for GDPR documentation. Compliance tasks involve generating documents such as data processing agreements or records of processing activities, which both require linguistic accuracy and adherence to regulatory formats. These tasks differ significantly from traditional legal tasks like case retrieval or logical reasoning, highlighting the need for tailored benchmarks that test LLMs on their ability to generate structured, regulatory-compliant output.

This study addresses these gaps by introducing benchmarks tailored to GDPR documentation tasks. The proposed benchmarks evaluate the ability of LLMs to generate structured outputs that meet compliance requirements, with a focus on accuracy, regulatory adherence, and integration into dynamic legal environments. Thereby, this study advances the evaluation of LLMs for regulatory compliance tasks, providing a framework that bridges the gap between general legal reasoning and compliance-specific applications.

Building on the evaluation of LLMs, their use in the legal domain poses unique challenges. Complex legal language, jurisdictional differences, and evolving laws highlight key limitations. The next section explores these challenges and their implications for compliance and ethics.

2.4. Challenges of Applying LLMs in the Legal Domain

The application of LLMs in the legal domain faces unique challenges due to the complexity and specificity of legal language, with specialized terminology, intricate phrasing, and ambiguity that often requires contextual interpretation [2]. General-purpose LLMs, trained on broader datasets, struggle to capture these nuances. This leads to potential misinterpretations and inconsistencies in the treatment of statutory language, legal precedents, and case law [16,19]. Another problem in environments where factual precision is essential is hallucination. LLMs tend to generate plausible but incorrect information. This is often due to data limitations, as legal texts are underrepresented in LLM training datasets, which prevents these models from acquiring the domain-specific knowledge necessary for accurate legal reasoning [2]. In addition, legal systems vary widely across jurisdictions, and legal terminology can vary by language and context. This requires extensive jurisdiction-specific data and fine-tuning to avoid inaccurate interpretations. However, this fine-tuning is resource-intensive, as legal prompts and documents are typically long. As processing requirements increase with input length, customization becomes costly and scalability across multiple jurisdictions is limited [2]. According to Paidu et al. [2], a major limitation to the integration of LLMs in the legal domain is the static nature of LLM knowledge. LLMs trained on static datasets lack awareness of legal changes, which can lead to regulatory and ethical challenges. For example, in jurisdictions governed by privacy regulations like the GDPR, models must ensure compliance with the most up-to-date version of the law. Moreover, the use of LLMs in the legal domain raises ethical concerns around data protection, bias in decision-making, and accountability [2].

In summary, although great progress has been made regarding the application of LLMs to legal tasks, substantial gaps remain in their evaluation with regard to compliance-specific applications. No existing tool or benchmark provides structured, regulatory-compliant output catering to the specific requirements of GDPR documentation. This work addresses the shortcomings as mentioned above by introducing GDPR-specific benchmarks and experiments that evaluate open-source and closed-source models on a representative compliance task. This involves checking their ability to produce correct, formatted output and follow dynamic legal standards. The next section outlines the methodology for testing these capabilities.

3. Methodology

In this section, we describe the methodology applied to select and evaluate LLMs for the experiments, along with the experimental approach and the specifics of the use case.

3.1. LLM Selection

We present a selection of prominent state-of-the-art LLMs chosen for our experiments and outline the criteria for their selection. To establish a baseline for high-quality general text generation, the study included GPT-4, a closed-source model from OpenAI. This selection was based on its performance on prominent general benchmarks [20]. For comparison, four open-source models were selected based on five main factors.

1. Pretraining. Pretraining allows LLMs to learn broad language patterns, vocabulary, and basic factual knowledge by analyzing large, diverse textual datasets [21]. This foundational knowledge is essential for recognizing legal terminology for tasks in regulatory contexts, such as the GDPR. Instruction-tuning refines these skills by teaching the model to follow specific task instructions [22]. This improves the ability to generate structured and contextual responses. This is particularly important for legal tasks, for which precision in format and terminology becomes crucial, as it aligns the model output with structured prompts typical of GDPR documentation requirements.
2. Local deployment. Models should be deployable to local machines, as this keeps sensitive data in a controlled environment and ensures privacy, which is essential for GDPR compliance. Moreover, this setup prevents data from being exposed to third-party servers, reducing the risk of unauthorized access and interception.
3. Size. To ensure applicability and usability on consumer hardware (NVIDIA 3090 GPU), models were limited to 8 billion parameters.
4. License. The models should have a permissive license such as Apache 2.0 [23] or MIT [24] to make them easy to use in smaller organizations.

5. Quantitative evaluation. The models were evaluated based on the HuggingFace open-llm-leaderboard [25], which ranks and presents LLMs based on their performance on established benchmark tasks. It provides a central hub for researchers and practitioners to compare and evaluate the capabilities of different LLMs in various applications. It comprises five main benchmarks: IFEval (Instruction-Following Evaluation) [26], BBH (Big-Bench Hard)[27], GPQA (Graduate-Level Google-Proof QA Benchmark) [28], MUSR (Multistep Soft Reasoning)[29], and MMLU-PRO [30]. These benchmarks reflect skills such as following instructions, reasoning, and problem solving. As such, they are highly relevant to the selection of LLMs for GDPR compliance roles, as they provide insight into the handling of structured, nuanced prompts and complex reasoning, which are both essential for accurate legal and regulatory responses.

Our selection, presented in Table 1, was mainly based on the open-llm-leaderboard scores [25]. We chose four models backed by renowned tech companies and leaders in AI technology such as Meta, Alibaba, and HuggingFace. All selected models were pretrained and followed instructions well. These models were also available in smaller versions for local deployment on consumer-grade hardware via HuggingFace, with permissive licenses that allowed for their flexible use in different organizational environments.

While the five criteria provided a robust foundation for model selection, we acknowledge some limitations. For instance, relying on general-purpose benchmarks such as IFEval and GPQA did not fully capture the nuances of legal reasoning or the specific requirements of regulatory compliance. Additionally, limiting models to 8 billion parameters excluded larger models that might have shown superior performance but required more extensive computational resources.

Factors such as interpretability, cost-effectiveness, and fine-tuning for specific legal domains were also considered but not prioritized in this study. Our focus was to evaluate model accuracy and feasible deployment in privacy-compliant environments. Future research could explore these aspects further and incorporate specialized legal benchmarks to complement the general-purpose metrics used here.

Based on these five criteria, we identified a set of LLMs that balanced performance, accessibility, and compliance with GDPR-specific requirements. The selected models included both state-of-the-art open-source options and a closed-source baseline to provide a comprehensive comparison. Table 1 summarizes the key characteristics of these models, highlighting their suitability for GDPR documentation tasks.

- Qwen2-7B [31], released by Alibaba, was chosen due to its strong performance in multilingual contexts, as it was trained in 27 languages. As GDPR compliance often involves handling data in multiple countries within the EU with different languages, Qwen2-7B is well suited for applications in different linguistic environments. With an average score of 42.91 on the leaderboard, the model ranked among the top performing open-source LLMs as of July 2024, making it a reliable choice for GDPR documentation tasks.
- Meta-Llama-3-8B [32] was released in April 2024 by Meta and is trained on an offline dataset. This model is optimized for interactive, instruction-driven use cases, which aligns well with the requirements of GDPR documentation, where precise and structured responses are required. This ability is underlined by high performance on benchmarks such as MUSR and GPQA, which test reasoning and problem-solving skills. This suggested that it could effectively deal with the structured complexity of the GDPR categories.
- zephyr-7b-beta [33] was created by the H4 Team of HuggingFace, and introduced on 25 October 2023. zephyr-7b-beta is based on the popular Mistral-7B model and was tuned with UltraChat [34] and UltraFeedback [33] datasets to improve the quality of instruction-following. The high benchmark performance, particularly in MMLU-PRO and IFEval, demonstrates that zephyr-7b-beta effectively handles complex prompts

and instruction-following tasks, making it a strong candidate for GDPR documentation generation.

- orca_mini_v7_7b [35] was created by Pankaj Mathur, one of the leading LLM engineers on HuggingFace. The model was released in May 2024 and is a fine-tuned version of the Qwen2 model. This model was chosen for its approach to overcoming size limitations through imitation learning techniques that mimic the reasoning processes found in larger models [36]. Fine-tuning on orca-style datasets [36] makes it particularly adept at handling nuanced regulatory information and legal reasoning tasks.
- GPT-4 [20] released by OpenAI in March 2023, excels at complex tasks, outperforming all state-of-the-art systems on traditional NLP benchmarks, making it the most capable model as of July 2024. It is also known to excel at complex reasoning and nuanced instruction-following tasks. GPT-4 sets a high standard for handling complex prompts and language, making it an ideal baseline against which to compare open-source models.

Table 1. Metadata of the selected Large Language Models.

Model	Release Date	Training Data	License	Model Size	Publisher
Qwen2-7B [31]	May 2024	Public web data in 27 languages	Apache 2.0	7 billion parameters	Alibaba
Meta-Llama-3-8B [32]	April 2024	Offline dataset	Llama3 Community License	8 billion parameters	Meta
zephyr-7b-beta [33]	October 2023	Mix of publicly available, synthetic datasets	MIT	7 billion parameters	HuggingFaceH4
orca_mini_v7_7b [35]	May 2024	Public web data and various SFT datasets	Apache 2.0	7 billion parameters	Pankaj Mathur
GPT-4 [20]	March 2023	Proprietary data	Proprietary	>1 trillion parameters	OpenAI

Other high scoring open-source models from the leaderboard were considered in our selection. The Mistral model was excluded because the Zephyr-7B-beta model, which is based on Mistral, scored higher on the leaderboard in July 2024. While zephyr-7B-beta incorporates additional fine-tuning with datasets such as UltraChat [34] and UltraFeedback [33], its selection was based on its strong performance as a pretrained and instruction-tuned model. In contrast, other fine-tuned models on the leaderboard were excluded due to nontransparent training processes and datasets. Many of the top performing models were fine-tuned by community members without detailed documentation of the datasets or methodologies used. This lack of transparency could introduce unknown biases or limitations, making these models less suitable for the goal of our study. By prioritizing models with well-documented pretraining and instruction-tuning processes, we ensured a neutral assessment of foundational performance while providing a robust baseline for future fine-tuning in GDPR-specific contexts.

The next step involved applying the selected models within the targeted use case. We assessed the models in generating data categories for a report of processing activities in GDPR documentation.

3.2. Use Case

Organizations are obliged by the GDPR to record their processing activities of personal data. Each record of a processing activity must include specific fields, such as the purpose of processing, the legal basis, deletion rules, or categories into which the processed data can be classified. In this study, we focused on data category generation—such as names, email addresses, health data, and financial information—as a representative task in GDPR documentation. Accurate generation of data categories is essential for GDPR compliance, as it defines the scope of data processing. These categories also affect adherence to other compliance principles, such as purpose limitation and data minimization.

To standardize our evaluation, each LLM was instructed to generate exactly ten data categories for the processing activity *operation of a webshop*. This number was chosen based on the average number of categories observed in our dataset of GDPR compliance records. Ten data categories struck a balance between smaller processing activities with limited contexts and larger, more extensive operations with broader contexts. Note that this ensured that the task reflected real-world scenarios while maintaining a manageable scope for evaluation.

Figure 4 illustrates our setup, presenting an example of the desired output quality. That example served as the benchmark for evaluating the model performance. By focusing on that task, we aimed to evaluate the potential for partially automating the creation of GDPR documentation and ultimately explore whether LLMs could contribute to reliable, scalable compliance solutions.

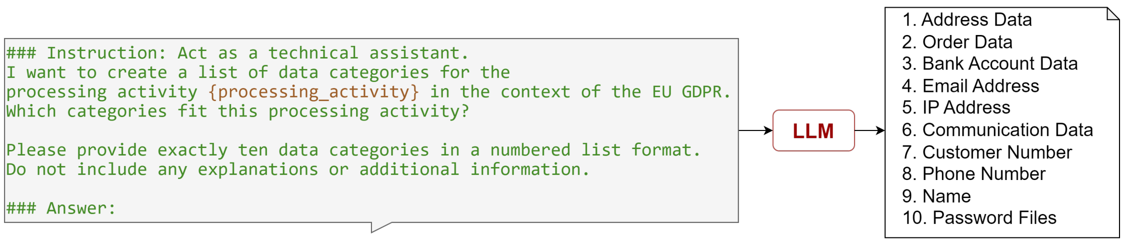

Figure 4. Use case for LLM application in document drafting for GDPR compliance.

3.3. Experimental Goals

With the use case defined, our experiments aimed to evaluate how well each model could perform that task under varying conditions. The experimental focus of this work was on the comparative analysis of four open-source and one closed-source LLM on the presented use case. GPT-4 served as a performance benchmark due to its strong results in general and legal benchmarks such as Lawbench [16] and LaiW [18], making it an ideal baseline for assessing whether open-source models could achieve similar accuracy and reliability in compliance-oriented applications. Comparing open-source models with GPT-4 was crucial for several reasons:

- Accessibility and cost. Open-source models are accessible and free to use, making them a viable option for organizations with limited resources. Demonstrating that they can perform comparably to GPT-4 can encourage wider adoption and innovation of open-source LLMs in the legal domain.
- Transparency and control. Open-source models allow organizations to understand and control the underlying mechanisms, ensuring better compliance with data privacy regulations such as the GDPR.
- Privacy and security. Open-source models can be deployed locally, mitigating the risks associated with transmitting data to third-party servers, which is a major concern with closed-source models.

This study also examined the rate of improvement in open-source models when using prominent techniques for enhancing input context, namely, few-shot prompting [5] and Retrieval-Augmented Generation (RAG) [6]. Few-shot prompting and RAG were explored as techniques for improving model performance by providing additional contextual information. This approach is particularly valuable for GDPR-related tasks, where accuracy and context adherence are essential. Achieving this would be a significant step towards establishing LLMs as compliant legal assistants under regulations such as the GDPR.

Alternative evaluation frameworks, such as LegalBench [17] and LawBench [16], were considered during the design of this study. However, these frameworks primarily evaluate tasks such as classification, extraction, and general legal reasoning, which are not directly aligned with the structured output and domain-specific requirements of GDPR documentation. The chosen framework emphasized criteria and tasks uniquely tied to GDPR compliance, ensuring alignment with the objectives of the study. By tailoring our evaluation to the specific needs of compliance tasks, we aimed to provide a more targeted assessment of LLM capabilities in this critical regulatory domain.

3.4. Experimental Setup

Building on these goals, this section outlines our experimental setup designed to evaluate the capabilities and constraints of LLMs in generating GDPR-compliant data categories for the record of a processing activity. Our experiments were split into four parts, as depicted in Figure 5.

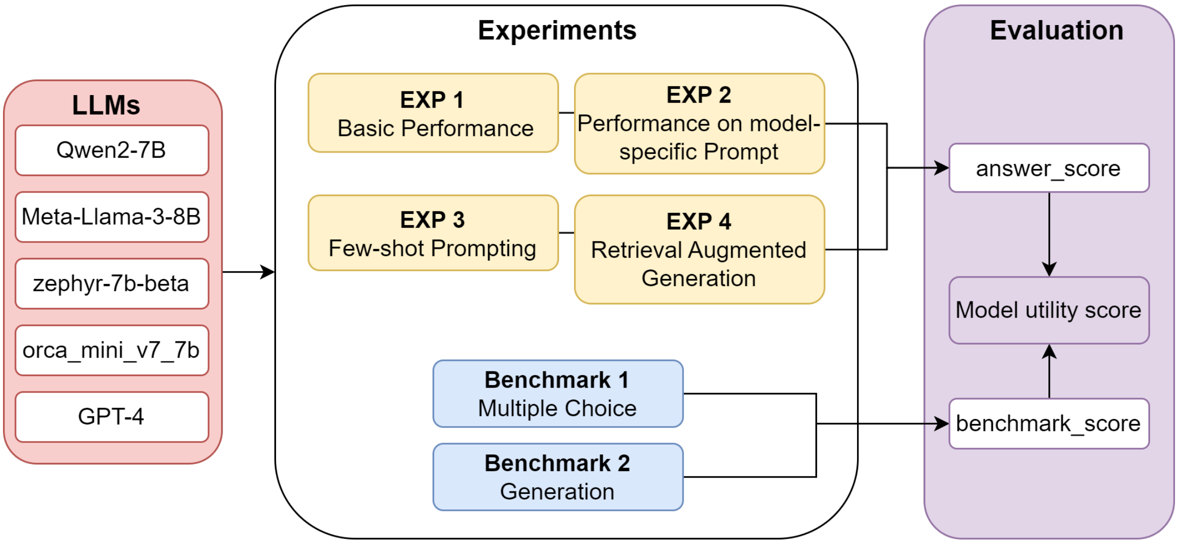

Figure 5. Experiment design for testing LLMs in generating data categories for a record of a processing activity, a regulatory task in GDPR compliance.

3.4.1. Experiment 1—Basic Performance

The primary objective of Experiment 1 was to evaluate the out-of-the-box performance of both open-source and closed-source LLMs in generating GDPR-compliant data categories. That experiment aimed to establish a baseline of the capabilities of these models, without any additional training or context augmentation. By comparing the unmodified outputs of the different models, we identified initial strengths or weaknesses and laid the groundwork for later experiments with enhanced prompting and context augmentation techniques. Although accuracy was a priority for GDPR-related tasks, latency was also measured to assess the feasibility of each model for real-world applications for which responsiveness could impact usability.

3.4.2. Experiment 2—Performance on Model-Specific Prompt

Based on findings on prompt-based learning frameworks reported in [37], we hypothesized that model-specific prompts, aligned with the pretraining format of each model, could improve the quality of GDPR-compliant outputs. Experiment 2 was designed to rigorously test that hypothesis by comparing tailored prompts against a standardized baseline set in Experiment 1. As LLMs are trained on extensive datasets using specific prompt formats designed to optimize their understanding and response generation, we hypothesized that adhering to these familiar formats during inference could enhance the ability of the models to leverage their training, thereby improving the overall quality of their responses. However, it had yet to be proven whether such alignment would yield any measurable improvements, in particular for highly structured, legal-domain tasks such as GDPR compliance. In Experiment 2, the investigation of whether the benefits due to prompt alignment, observed in general tasks, extended to regulatory contexts was pursued, regardless of the outcome.

3.4.3. Experiment 3—Few-Shot Prompting

In Experiment 3, we applied few-shot prompting [5] as a technique to improve the model accuracy without retraining. This is particularly promising for domain-specific tasks such as GDPR documentation. Few-shot prompting provides a few examples, in this case, three, to the model during inference to condition its predictions without updating the model weights. By providing three examples of processing activities with associated data categories, we hypothesized that the model would better understand the format and structure required for GDPR-compliant outputs.

3.4.4. Experiment 4—Retrieval Augmented Generation

Experiment 4 used Retrieval Augmented Generation (RAG) [6] to evaluate model performance when accessing external resources relevant to the use case. RAG is a text generation paradigm that combines traditional retrieval techniques with LLMs. In RAG, the model retrieves relevant text segments from a large corpus of text data based on the input query and then uses these retrieved texts to guide and improve the generation process [6]. This approach helps to leverage external knowledge explicitly, influencing the quality and informativeness of the generated text by providing concrete references during generation. While RAG has the potential to improve accuracy, it presents challenges, particularly in aligning retrieved text with input prompts and addressing the formal legal language of GDPR texts. To mitigate these issues, the following strategies were implemented:

- Contextual pre-processing. The GDPR text was segmented into semantically coherent chunks, ensuring retrievals were contextually relevant.
- Prompt engineering. Prompts were refined to better align informal user queries with formal legal language, improving retrieval compatibility.
- Retrieval filtering. Retrieved segments were filtered for semantic relevance to reduce noise in the generation process.

These measures aimed to compensate for the deficiencies in the retrieval process and enable RAG to make better use of structured legal language in GDPR. Experiment 4 investigated whether RAG improved the generation of data categories in GDPR compliance and identified further areas of refinement for retrieval-based approaches.

3.4.5. Setup Details

To facilitate reproducibility, all experiments were conducted under consistent environmental configurations. The hardware used included a system with an NVIDIA 3090 GPU, 24 GB of VRAM, and 64 GB of RAM, running on Ubuntu 20.04 with Python 3.8 and the HuggingFace transformers library, version 4.42.4. The code for our experiments is available on GitHub [38].

3.5. Evaluation Criteria

With the experimental setup established, we present the evaluation criteria that define how model performances were evaluated, ensuring a structured and objective comparison across the experiments. These criteria provided a structured framework for comparing the output quality of the models. The evaluation consisted of two parts: model benchmarks and criteria for evaluating the answers generated in each experiment. Both aspects were evaluated using several subcriteria. Models received scores based on how well they met each criterion. These scores were then weighted and summed to calculate a model utility score, which was used to compare the models within the use case.

3.5.1. Benchmarks

For the initial model evaluation, we designed benchmarks specifically for GDPR documentation generation. The multiple-choice benchmark evaluated the knowledge of GDPR requirements, asking models to select appropriate data categories for specific processing activities. The generation benchmark evaluated the quality and stability of responses as the model generated data categories under different prompts, ensuring adaptability and accuracy under different formulations.

Multiple-choice benchmark. To evaluate GDPR contextual knowledge, we developed a benchmark consisting of 25 multiple-choice questions. Each question required selecting the data categories that best corresponded to a specific processing activity from eight options, testing the model's ability to recognize GDPR-specific data categories. For example:

> Which data categories are appropriate in the context of GDPR for the processing activity entitled "time tracking " with the description "recording the working hours of individual employees to fulfill the duty of proof"?
>
> a. Date and time of the query
> b. Working hours
> c. Communication data
> d. Sick days
> e. Vacation days
> f. Name
> g. Phone number
> h. Age

The benchmark was evaluated with a maximum of 5 points per model based on the following metrics:

1. Diversity (1 point). Diversity assesses whether the model provides diverse, contextually appropriate answers to the questions. A lack of diversity could indicate a failure to understand the nuances of different GDPR categories and processing activities. Accordingly, if a model lacked diversity in its responses, it scored 0 points for the entire benchmark. Otherwise, it was awarded 1 point.
2. Accuracy (0–2 points). Accuracy [39] measures the correctness of answers, which is essential in GDPR documentation, as accurate data categorization ensures that organizations comply with legal obligations regarding specific data types. Two points were awarded for an accuracy of >75% and one point for an accuracy of >60%.
3. F1 Score (0–2 points). The F1 score [39] emphasizes the balance between precision and recall, which is critical in GDPR tasks to ensure that models reliably identify all relevant categories without including irrelevant ones. Again, 2 points were awarded for an F1 score of >75%, and 1 point was awarded for an F1 score of >60%.

Generation benchmark. The generation benchmark consisted of a series of tasks in which models inferred 25 exemplary processing activities using five different prompts. Scoring involved comparing the generated responses with the correct data categories. As the models were asked to generate data for ten categories in the experiments, only processing activities associated with ten or more corresponding data categories were included in this benchmark. The difficulty of achieving a full score varied, as some questions were associated with only ten categories, while the maximum number of associated categories was 36, making it easier to achieve higher scores. Models could achieve a maximum score of 100% on this benchmark if all generated categories matched those in the dataset. Notably, the model was consistently prompted with five standardized prompts, with the processing activity changing every five iterations. The prompts are listed in Figure 6. This benchmark measured the ability of a model to consistently generate accurate data categories for a record of a processing activity, ensuring that it could handle legal language and structured requirements in different scenarios. Final scores were assigned based on the percentage of correct answers: Models scoring above 50% received 5 points, those scoring 45–50% received 4 points, 40–45% 3 points, 35–40% 2 points, 30–35% 1 point, and scores below 30% received 0 points.

Instruction: act as a technical assistant

> I need a list of data categories relevant to the processing activity Absence Time Tracking within the framework of the EU GDPR. Please provide exactly ten suitable data categories.

> For the processing activity Applicant Management, identify exactly ten data categories that are pertinent under EU GDPR regulations.

> Considering the processing activity Health Management in the context of EU GDPR, list exactly ten appropriate data categories.

> For the given processing activity Employee Discussion, what are exactly ten relevant data categories according to EU GDPR?

> Please provide a list of exactly ten data categories that fit the processing activity Subscriptions as per EU GDPR guidelines.

Answer

Figure 6. Prompt variations in the generation benchmark. Each prompt was applied to five processing activities.

Building on the benchmarks, the next step involved a detailed evaluation of the generated answers to ensure their alignment with GDPR requirements. That evaluation applied specific criteria to assess the quality and compliance of the outputs, providing a more nuanced analysis of model performance.

3.5.2. Answer Evaluation

To further ensure that the output met GDPR requirements, each generated answer was scored on five criteria relevant to regulatory compliance tasks. Each answer could receive between 0 and 5 points for each criterion. The scoring is detailed below and summarized in Table 2.

- Latency. Efficient document drafting is valuable for GDPR compliance, as responsiveness affects the feasibility of the solution in real-world applications. Points were awarded as follows: 5 points for latency under 5 s, 4 points for under 7.5 s, 3 points for under 10 s, 2 points for under 12.2 s, 1 point for under 15 s, and 0 points for 15 or more seconds.
- Structure and style. GDPR documentation often follows a strict formatting to ensure clarity and consistency across records. This criterion checked whether the model output a structured list with exactly ten bullet points in clear, straightforward language with no repetitions of words. Proper formatting helps avoid ambiguity and supports auditors in verifying compliance. Each fulfilled aspect earned 1 point, with a total possible score of 5 points.
- Grammar. Grammatical accuracy is critical in the legal domain to prevent misinterpretation of legal documentation. Correct grammar contributes to the credibility and readability of the document, ensuring that records are unambiguous and meet professional standards in legal documentation. Points were awarded based on the number of grammatical errors: 5 points for no errors, 4 points for 1 error, 3 points for 2 errors, 2 points for 3 errors, 1 point for 4 errors, and 0 points for more than 4 errors. Answers written in another language than English automatically scored 0 points.

- Validity. This criterion assessed the relevance of each generated category according to GDPR requirements. Categories that are not related to GDPR, such as analytics or marketing data, must be excluded to ensure that the outputs are in line with legal guidelines. A high validity score means that the data categories are relevant and legally appropriate, which is critical to maintaining regulatory compliance. Scores were awarded as follows: 5 points for 100% valid categories, 4 points for 90%, 3 points for 80%, 2 points for 70%, 1 point for 60%, and 0 points for less than 60%.
- Contextual understanding. In GDPR documentation, understanding the context of data processing activities is essential. This criterion evaluated whether the model captured the full range of relevant categories for a given activity (e.g., covering customer contact data, order information, and communication data for an e-commerce scenario). Comprehensive contextual understanding ensures that documentation accurately represents all necessary facets of data processing for legal compliance. One point was awarded for an answer free of redundancy, ensuring that categories were not duplicated. Another point was awarded for including specific data fields within categories (e.g., "Customer Data (Name, Address, Contact Information)"). The final three points were awarded based on context coverage. Therefore, the context for our example *operation of a webshop* was divided into six parts, with each part earning 0.5 points if included.
    1. Customer contact (phone number, address, email)
    2. Order (customer number, order number, products, price)
    3. Payment (credit card info, payment data)
    4. User profile (IP address, password, username)
    5. Communication data (support requests, ratings)
    6. Personal data (gender, name, age, date of birth)

Table 2. Scoring criteria for answer evaluation.

Criterion	Description and Scoring	Weight
Latency	Points based on response time: >5 s (5), >7.5 s (4), >10 s (3), >12.5 s (2), >15 s (1), <15 s (0).	1
Structure and Style	Evaluates clarity: list format (1), 10 bullets (1), precise language (1), simplicity (1), no repetition (1).	2
Grammar	Assesses errors: no errors (5), 1 error (4), 2 errors (3), 3 errors (2), 4 errors (1), >4 errors (0).	3
Validity	Relevance to GDPR guidelines: 100% (5), 90% (4), 80% (3), 70% (2), 60% (1), <60% (0).	4
Contextual Understanding	Measures comprehensiveness: no redundancy (1), specific fields (1), coverage of six key contexts (3).	5

3.6. Utility Score Calculation

Finally, to calculate the utility scores, we weighted these scores according to their influence on answer quality, with weights ranging from 1 to 5. The most important aspects of a high quality answer were domain knowledge and factual correctness. Therefore, contextual understanding was weighted with 5, and validity was weighted with 4. Credibility, which was tied to the absence of grammatical errors, led to grammar being weighted with 3. Structure and style, which ensured comparability of answers, were weighted with 2. Finally, latency was weighted with 1, since the generation time did not affect the correctness of the answer.

The calculation of the utility score is summarized in Figure 7. For each experiment, an answer_score was calculated by multiplying the weights with the scores of each category. These scores were then summed across all experiments and averaged by dividing the sum by 4. Finally, the benchmark scores were weighted with the maximum weight of five, as the benchmarks allowed for a quantitative analysis of the model performance in the use case, and then added to the experiment score.

In the following section, we present the results of the experiment and apply the defined model evaluation criteria.

Model Utility Score

experiment_score = latency_score x 1 + structure_score x 2 + grammar_score x 3 + validity_score x 4 + context_score x 5 **/ 4**

+

benchmark_score = mc_benchmark_score x 5 + generation_benchmark_score x 5

Figure 7. Calculation of the model utility score.

4. Experiments and Results

This section presents the results of the experiments described in Section 3.4. The experiments focus on evaluating open-source models against the closed-source GPT-4 in terms of key criteria essential for GDPR compliance: latency, structure, grammar, validity, and contextual understanding. For each experiment, the results are shown in Table 3.

Table 3. Evaluation scores of answers in each experiment.

Model	Experiment	Latency	Structure and Style	Grammar	Validity	Contextual Understanding
Qwen2-7B	**Exp 1**	5	5	5	5	5
	Exp 2	0	4	5	5	4
	Exp 3	5	5	5	4	5
	Exp 4	3	2	5	5	4
Meta-Llama-3-8B	**Exp 1**	0	3	5	5	5
	Exp 2	5	4	5	5	3.5
	Exp 3	0	4	5	4	3.5
	Exp 4	3	2	5	5	1
zephyr-7b-beta	**Exp 1**	3	5	5	5	5
	Exp 2	4	5	5	5	5
	Exp 3	0	4	5	4	4
	Exp 4	1	2	5	5	5
orca_mini_v7_7b	**Exp 1**	5	5	5	4	5
	Exp 2	5	5	5	4	4
	Exp 3	5	5	5	4	4
	Exp 4	4	2	5	5	3
GPT-4	**Exp 1**	5	5	5	5	4
	Exp 2	5	5	5	4	4
	Exp 3	5	5	5	5	3.5
	Exp 4	2	2	5	5	4

4.1. Experiments

Overall, the results indicated that the open-source models performed comparably to GPT-4, especially in grammar and contextual understanding. While GPT-4 remained slightly ahead in consistency across all categories, open-source models such as Qwen2-7B and orca_mini_v7_7b performed similarly in our experiments, showing potential for GDPR compliance tasks. The performance differences between the models highlighted specific areas where open-source models excelled and where further tuning may be required to fully meet GDPR requirements.

Experiment 1—basic performance. Experiment 1 established a baseline for out-of-the-box capabilities. The experiment assessed the natural ability of the models to generate GDPR-compliant data categories, without specialized prompts. Here, all models, including the open-source options, performed well in grammar, structure, and contextual understanding, with Qwen2-7B and GPT-4 achieving the highest scores. The competitive performance of the open-source models suggested that they were well-suited for handling structured legal text generation tasks. Latency varied across the models, with GPT-4 and orca_mini_v7_7b generating responses faster than other open-source options, which could be advantageous in practical applications requiring timely outputs. For small and medium enterprises handling time-sensitive compliance requests, this latency difference could be a deciding factor. Future studies could investigate latency optimization to improve the responsiveness of open-source models for such scenarios. GPT-4 showed lower latency, which is very beneficial when real-time interaction is required, for example, answering Data Subject Access Requests within the 30-day deadline under the GDPR. However, latency for Qwen2-7b remained acceptable for batch processing tasks like periodic audits of processing activities.

These results confirmed that open-source models had strong baseline potential. For example, the structured outputs and contextual accuracy of Qwen2-7B made it well suited for automating records of processing activities, where detailed documentation is required under GDPR Article 30. By reducing errors in categorization, these models can reduce the workload for compliance officers, particularly in repetitive documentation tasks.

Experiment 2—performance on model-specific prompt. In Experiment 2, we tested whether model-specific prompts aligned with the pretraining format could improve model performance when generating GDPR documentation. Surprisingly, the results showed that no model improved with its specific prompt compared to the standardized one, with some models even showing slight declines in validity and contextual understanding. Zephyr maintained its quality, while all other models performed worse, especially in terms of validity. However, the scores still ranged between 3.5 and 5, maintaining a fairly good overall response quality. This finding underscores that complex prompt customization does not necessarily lead to better results for GDPR-related tasks. Instead, simplicity and clarity of prompts may lead to better results across models, suggesting that optimization of prompt design should focus on transparency rather than pretraining alignment alone.

Experiment 3—few-shot prompting. Experiment 3 tested the effect of providing context to the model through prompting. Contrary to our expectations, few-shot prompting had no significant effect on answer quality. Most models maintained high scores in validity and contextual understanding, although GPT-4 showed slightly better contextual accuracy than the open-source models. Interestingly, Qwen2-7B outperformed GPT-4 in certain aspects of answer validity, suggesting that they may be able to align with specific data categories under GDPR requirements. This suggests that open-source models can effectively use context in compliance tasks, even if few-shot prompting does not significantly impact overall performance. For instance, the ability of Qwen2-7B to align with GDPR data categories highlights its utility in data subject access requests, where accurate and contextual retrieval of structured information is critical. However, the slightly better contextual accuracy of GPT-4 suggests it may be better suited for tasks requiring nuanced legal reasoning, such as proportionality assessments under GDPR Article 6 [3].

Experiment 4—RAG. In Experiment 4, we extended the context provided to the model during inference using the RAG technique. RAG proved beneficial for tasks directly covered in the source documents, as models accurately retrieved relevant segments from known processing activities. However, RAG struggled with novel data categories that were not present in the source text, resulting in less structured responses from all models. This limitation affects tasks like generating records of processing activities, where precise categorization is necessary to demonstrate compliance with GDPR Articles 5 and 30 [3]. Furthermore, all of the models, including GPT-4, ignored the structured list format, outputting plain text instead of the required list format.

These findings indicate that RAG significantly improves performance for known categories by providing relevant context but becomes less effective when dealing with novel categories. In particular, providing the model with the GDPR itself as a source document had no effect. This is due to significant differences between the language in the prompt and the legal phrasing and structure in the GDPR text. These differences make it difficult to retrieve contextually useful content to generate records of processing activities. Consequently, the models were unable to infer from the embedded GDPR content, highlighting a limitation in using broad legal documents as reference material for highly specialized tasks. This indicates a need for fine-tuning models on domain-specific datasets, such as annotated GDPR case studies, to enhance their ability to align with legal phrasing and structure. Moreover, an observed tendency of the models to disregard structural instructions suggests that RAG, as implemented here, may not fully support structured outputs in legal document drafting where adherence to format is critical for compliance.

The experimental findings offer valuable insights into model performance under specific conditions. To complement this analysis, we present the benchmark results in the following. This provides a broader, standardized evaluation of model capabilities in GDPR compliance tasks.

4.2. Benchmarking

For a quantitative analysis of the model performance in the use case, we created the two benchmarks described in Section 3.5.1. The results are summarized in Tables 4 and 5.

4.2.1. Multiple-Choice Benchmark

The multiple-choice benchmark evaluated the ability to select GDPR-compliant data categories, testing knowledge and accuracy. The models were assessed based on three metrics: diversity, accuracy, and F1 score. All models showed diversity in their responses, reflecting their ability to generate varied yet contextually relevant responses. In terms of accuracy and F1 score (see Figure 8), Qwen2-7B achieved high scores of 0.78. This highlights a high level of precision and recall in identifying GDPR-compliant data categories. This minimizes the risk of misclassifying sensitive data and reduces the likelihood of compliance violations. It also reduces the reliance on manual documentation, which is both time-intensive and prone to human error.

The final results, summarized in Table 4, indicate that in the context of GDPR document drafting, open-source models can provide precise and varied responses without requiring proprietary resources. This finding supports the potential for open-source LLMs to be used in GDPR compliance tasks, offering accessible and adaptable solutions that meet regulatory requirements in a cost-effective way.

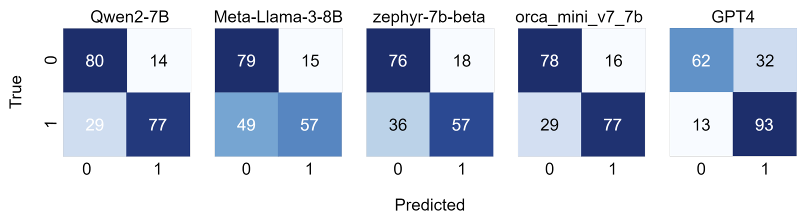

Figure 8. Confusion matrices for the results of the multiple-choice benchmark per model. True positive (TP) = true: 1, predicted: 1. False positive (FP) = true: 0, predicted: 1. True negative (TN) = true: 0, predicted: 0. False negative (FN) = true: 1, predicted: 0.

Table 4. Scores per model for the multiple choice benchmark.

Model	Accuracy	F1 Score	Diversity	Overall Score
Qwen2-7B	0.785–2 points	0.785–2 points	yes–1 point	5
Meta-Llama-3-8B	0.680–1 point	0.676–1 point	yes–1 point	3
zephyr-7b-beta	0.730–1 point	0.729–1 point	yes–1 point	3
orca_mini_v7_7b	0.775–2 points	0.774–2 points	yes–1 point	5
GPT-4	0.775–2 points	0.769–2 points	yes–1 point	5

4.2.2. Generation Benchmark

The generation benchmark tested the ability to generate GDPR-compliant data categories for different processing activities, under different prompts, by comparing the generated responses with entries in a reference database. Benchmark scores were based on the percentage of generated data categories that matched those in the database, although that reference was not an exhaustive ground truth. As a result, the overall performance of the models was moderate, as shown in Table 5, with scores ranging from one to three points. Qwen2-7B and GPT-4 scored the highest. This highlights that Qwen2-7B is adept at generating structured lists of data categories, making it suitable for generating records of processing activities for GDPR compliance. Zephyr-7b-beta and orca_mini_v7_7b, however, scored lower. A major reason for the lower scores was the tendency of the models to use broader categorizations, often grouping several specific categories under a single term, such as combining "first name" and "last name" into a broader category such as "identificatory data". This reflects a balance between capturing overarching themes and losing granularity, which can impact compliance when specific distinctions are legally significant in GDPR documentation.

Table 5. Scores per model for the generation benchmark.

Model	Correct Answer Rate (%)	Score
Qwen2-7B	44.0%	3
Meta-Llama-3-8B	40.4%	3
zephyr-7b-beta	34.8%	1
orca_mini_v7_7b	34.8%	1
GPT-4	43.2%	3

The benchmark evaluation highlighted individual aspects of model performance. To provide a comprehensive comparison, we then calculated utility scores that integrated the benchmark scores with the answer evaluation.

4.3. Utility Evaluation

In the following, we combined the results of the experiments and the benchmarks as defined in Section 3.5 to derive a final utility score for each model concerning the use case. The utility scores balanced the results of the experiments and benchmarks and reflected accuracy, contextual understanding, and adherence to formatting requirements. The scores are listed in Figure 9 and Table 6.

The utility scores revealed that the open-source Qwen2-7B model led the performance rankings, even outperforming GPT-4. Qwen2-7B excelled in out-of-the-box performance and demonstrated a good contextual understanding throughout Experiments 1–3. This highlights its strength in tasks requiring immediate domain adaptation and structured response generation, offering organizations a cost-effective alternative for GDPR compliance tasks without sacrificing accuracy. GPT-4 continued to show a robust performance across the benchmarks. In particular, it excelled in the multiple-choice benchmark, highlighting its advanced understanding of the specifics of the GDPR. The high scores of GPT-4 in contextual understanding across the experiments ensured that edge cases, such as ambiguous data categories, were handled with greater accuracy, which reduced the risk of misclassification. Qwen2-7B proved that open-source models were a viable choice for GDPR compliance tasks. While GPT-4 exhibited lower latency, the 7–10 s delay in generating outputs from Qwen2-7B remained acceptable for batch processing tasks, ensuring that organizations could meet GDPR documentation timelines without significant interruptions. Furthermore, the capability of Qwen2-7B to generate structured lists with 90% accuracy can be directly applied to creating other GDPR-mandated records, such as data subject access requests. This would reduce the workload of compliance officers by automating repetitive tasks, allowing them to focus on legal review.

Among the other open-source models, orca_mini_v7_7b showed consistency in generation tasks, performing well in Experiments 1 and 2. Orca demonstrated strong knowledge retention, as reflected in its performance on the multiple-choice benchmark. However, its lower performance in the generation benchmark suggests limitations in handling unstructured tasks, which may reflect the need for more advanced prompt engineering. However, orca_mini_v7_7b is more resource-efficient, making it suitable for smaller organizations seeking compliance solutions on a budget. Conversely, Meta-Llama-3-8B was the only model to show adaptability in Experiment 4, suggesting an ability to handle novel contexts. Nevertheless, it struggled to maintain consistency across structured GDPR tasks, as evidenced by its moderate benchmark scores. In addition, the lower contextual understanding of Meta-Llama-3-8B could result in incomplete compliance documentation, requiring additional human review. This highlights the need for fine-tuning models on legal-specific datasets. Zephyr-7b-beta ranked lowest in overall utility. Nevertheless, it achieved the highest score in Experiment 2, demonstrating its adaptation to model-specific prompts. This suggests potential for fine-tuning and task-specific optimization, but also highlights weaknesses in generalization, as evidenced by its low performance on the generation benchmark.

The performance metrics of Qwen2-7B and GPT-4 demonstrate that LLMs are capable of automating critical GDPR documentation tasks, such as generating records of processing activities and data categorization. By reducing the manual effort required and improving accuracy, these models can streamline compliance workflows while minimizing the risk of errors that could lead to regulatory penalties. However, latency and contextual understanding remain areas for further refinement to fully align with operational needs. Building on these results, the following discussion explores their broader implications, focusing on the research questions and practical applications for GDPR compliance.

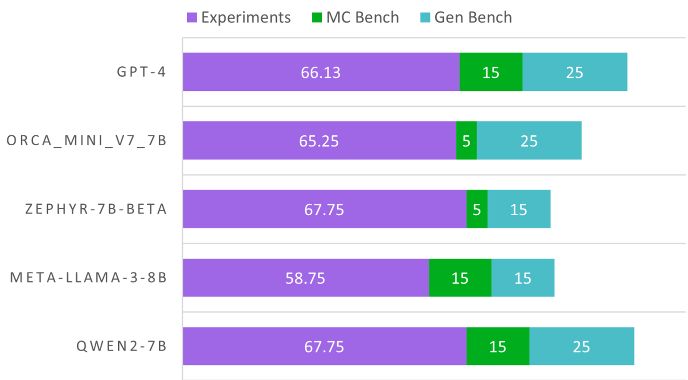

Figure 9. Overall utility scores per model. The score consists of the experiment score, multiple-choice benchmark score, and the generation benchmark score.

Table 6. Weighted scores per model in each experiment and benchmark.

Model	Exp 1	Exp 2	Exp 3	Exp 4	MC Bench	Gen Bench	Utility
Qwen2-7B	75	63	71	62	25	15	**107.75**
Meta-Llama-3-8B	66	65.5	56.5	47	15	15	**88.75**
zephyr-7b-beta	73	74	59	65	15	5	**87.75**
orca_mini_v7_7b	71	66	66	58	25	5	**95.25**
GPT-4	70	66	67.5	61	25	15	**106.125**

5. Discussion

In this section, we discuss our findings in relation to the research questions (RQs) and their implications for practice. We set the focus on the utility of LLMs in document drafting for GDPR compliance.

RQ1: Can open-source LLMs generate data categories for GDPR compliance documentation as effectively as GPT-4?

Our results show that open-source models, especially Qwen2-7B, are viable alternatives to closed models like GPT-4 for drafting GDPR documents. Allowing local deployment, open-source models increase the compliance of GDPR data transfer rules and give more control over sensitive data. This is important for small enterprises, where cost savings from reduced reliance on proprietary systems can balance initial deployment investments.

At the same time, deploying LLMs for compliance is fraught with challenges. The level of customization required to make models organization-specific and adapt to regional regulatory nuances is too high for smaller organizations. Furthermore, pretrained models with opaque datasets raise questions about biased outputs and a potential conflict with the accountability and transparency principles of the GDPR. Ensuring the outputs meet organizational needs will require careful integration with existing workflows and regulatory requirements, emphasizing the importance of adaptability and operational feasibility.

RQ2: To what extent do context-augmenting techniques such as few-shot prompting and Retrieval Augmented Generation (RAG) enhance LLM performance in drafting documents for GDPR compliance?

The experiments show mixed results for context augmentation techniques. Few-shot prompting yielded limited improvements, indicating that prompt design alone may not be sufficient for complex legal tasks. However, it is still a promising tool for aligning models with specific formatting requirements without retraining, particularly when combined with curated sample prompts reflecting real-world GDPR documentation.

While RAG was effective in retrieving results for predefined categories, it struggled with novel or ambiguous queries due to its reliance on static resources like the GDPR document. Moreover, the fact that RAG relies on predefined text sources, such as the GDPR document itself, points to a larger problem: the semantic gap between the formal legal language and user-specific queries. This gap limits the ability of retrieval models to generate outputs that are directly actionable without significant human intervention. Addressing these limitations will require dynamic updates to the resource database, fine-tuned embeddings for legal contexts, and hybrid retrieval methods combining semantic search with symbolic reasoning. Apart from these improvements, merging RAG with dynamic knowledge graphs, which evolve over time, could overcome some of the limitations of static retrieval systems. Such knowledge graphs may become more adaptive and relevant to changes in regulation or organizational policy, thus making outputs better suited for compliance tasks in an evolving context.

Limitations and Future Work

This study highlights key limitations that warrant further exploration. The first major challenge involves the need for models to better adapt to organization-specific workflows and regional regulatory nuances, which requires fine-tuning or prompt engineering to align outputs with unique internal documentation practices, organizational policies, and compliance structures. In general, such adaptation may be prohibitively expensive for smaller organizations with limited technical resources; therefore, there is a need for simplified fine-tuning processes or pretrained legal models for GDPR compliance. Moreover, this reliance on static datasets and benchmarks limits the evaluation of how well these models handle dynamic, real-world scenarios, such as rapidly evolving regulatory requirements or cross-jurisdictional compliance contexts.

Another critical limitation is inconsistent handling of ambiguous legal texts. For example, subtle differences in legal terminology across EU member states can result in outputs that do not meet the compliance requirements of a particular jurisdiction. Solving this problem might involve incorporating external legal knowledge bases, such as taxonomies or ontologies, which provide structured interpretations of ambiguous terms. Second, finer-grained domain-aware embeddings should help narrow the gap between user queries and more refined language in the documentation within the GDPR, so more effective output can be made of it. In fact, these approaches would still be strongly in need of essential research and testing for viability, scalability, and diversifying organizational needs.

Future work should be conducted on fine-tuning LLMs with GDPR-specific datasets, developing hybrid retrieval techniques that improve the accuracy of ambiguous scenarios, and leveraging adaptive knowledge graphs that can dynamically incorporate new regulatory interpretations. Addressing these challenges will help LLMs evolve into scalable and cost-effective tools that better meet organizational and regulatory requirements, enabling compliance both in structured and complex scenarios.

Overall, these findings reinforce the viability of LLMs, particularly open-source models such as Qwen2-7B, as transformative tools for GDPR compliance. To fully operationalize these models in legal workflows, organizations and researchers will have to address some key limitations that relate to their adaptability to specific workflows, their ability to deal with ambiguous legal texts, and their scaling for changing regulations. Meeting these challenges through targeted research and development, LLMs can act as that key enabler of scalable and cost-effective compliance in the legal domain.

6. Conclusions

This study explored the potential of LLMs, particularly open-source models such as Qwen2-7B, for automating GDPR compliance tasks, such as generating data categories for processing activity records. By demonstrating performance comparable to GPT-4 in structured scenarios, Qwen2-7B highlighted the feasibility of cost-effective, privacy-preserving alternatives to proprietary systems. Open-source models can more fully meet the strict data security requirements under GDPR, with the added benefit of supporting local deployment for better organizational control over sensitive information.

This study contributes to the growing field of AI in legal technology by validating the applicability of LLMs in compliance workflows. These models can automate repetitive work, such as the development of initial documentation, enabling human experts to focus their energy on higher-order decision-making. For practitioners, this underlines the need for the incorporation of safeguards such as validation pipelines, transparency regarding training data, and human review in iterations to secure outputs that meet both regulatory and ethical standards. While RAG and fine-tuned embeddings present opportunities for improving the adaptability and accuracy of these models, their implementations will require scalability, latency, and ambiguous legal context challenges to be overcome.

However, the study also identified critical limitations. The concentration on data category generation itself restricts generalizability to other tasks in GDPR, such as privacy impact assessments or consent management. Furthermore, reliance on pre-specified benchmarks risks failing to capture the nuances and constantly changing nature of real-world compliance scenarios. This indeed calls for more extended evaluation frameworks. Future work should pursue domain-specific fine-tuning, human evaluation, and applications for a wide range of regulatory contexts, such as the California Consumer Privacy Act (CCPA) [40], to extend the value of LLMs in legal compliance.

The ethical and legal consequences of using LLMs in such sensitive domains as regulatory compliance also call for further discussion. Among the questions that remain open is that of bias in pretraining data, accountability in automated decisions, and compliance with GDPR principles of transparency. For practitioners, it is important to have more specific implementation guidelines to close the gap between theoretical feasibility and operational deployment. With these challenges overcome, LLMs in future research can become robust, scalable tools that balance cost-effectiveness, privacy, and ethical considerations, thus transforming the landscape of compliance-driven applications.

Author Contributions: M.v.S. wrote the paper. M.R. corrected and supervised this work. All authors have read and agreed to the published version of the manuscript.

Funding: This research received no external funding.

Data Availability Statement: The original data presented in the study are openly available on GitHub at https://github.com/magdalenavonschwerin/llms-in-gdpr-documentation (accessed on 18 November 2024).

Conflicts of Interest: The authors declare no conflicts of interest.

Abbreviations

The following abbreviations are used in this manuscript:

AI	Artificial Intelligence
API	Application Programming Interface
GDPR	General Data Protection Regulation
LLM	Large Language Model
NLP	Natural Language Processing
RAG	Retrieval Augmented Generation
RQ	Research Question

References

1. Teubner, T.; Flath, C.M.; Weinhardt, C.; van der Aalst, W.; Hinz, O. Welcome to the era of ChatGPT et al.: The prospects of large language models. *Bus. Inf. Syst. Eng.* **2023**, *65*, 95–101. [CrossRef]
2. Padiu, B.; Iacob, R.; Rebedea, T.; Dascalu, M. To What Extent Have LLMs Reshaped the Legal Domain So Far? A Scoping Literature Review. *Information* **2024**, *15*, 662. [CrossRef]
3. European Parliament and Council of the European Union. Regulation (EU) 2016/679 of the European Parliament and of the Council. Available online: https://data.europa.eu/eli/reg/2016/679/oj (accessed on 18 November 2024).
4. Almeida Teixeira, G.; Mira da Silva, M.; Pereira, R. The critical success factors of GDPR implementation: A systematic literature review. *Digit. Policy, Regul. Gov.* **2019**, *21*, 402–418. [CrossRef]
5. Brown, T.; Mann, B.; Ryder, N.; Subbiah, M.; Kaplan, J.D.; Dhariwal, P.; Neelakantan, A.; Shyam, P.; Sastry, G.; Askell, A.; et al. Language Models are Few-Shot Learners. In *Advances in Neural Information Processing Systems*; Larochelle, H., Ranzato, M., Hadsell, R., Balcan, M.F., Lin, H., Eds.; Curran Associates, Inc.: New York, NY, USA, 2020; Volume 33, pp. 1877–1901.
6. Salemi, A.; Zamani, H. Evaluating Retrieval Quality in Retrieval Augmented Generation. In Proceedings of the 47th International ACM SIGIR Conference on Research and Development in Information Retrieval, Washington, DC, USA, 14–18 July 2024; pp. 2395–2400.
7. Li, H.; Su, W.; Wang, C.; Wu, Y.; Ai, Q.; Liu, Y. Thuir@coliee 2023: Incorporating structural knowledge into pre-trained language models for legal case retrieval. *arXiv* **2023**, arXiv:2305.06812.
8. Huang, Q.; Tao, M.; Zhang, C.; An, Z.; Jiang, C.; Chen, Z.; Wu, Z.; Feng, Y. Lawyer llama technical report. *arXiv* **2023**, arXiv:2305.15062.
9. Yao, S.; Ke, Q.; Wang, Q.; Li, K.; Hu, J. Lawyer GPT: A legal large language model with enhanced domain knowledge and reasoning capabilities. In Proceedings of the 2024 3rd International Symposium on Robotics, Artificial Intelligence and Information Engineering, Singapore, 5–7 July 2024; pp. 108–112.
10. Savelka, J.; Ashley, K.D. The unreasonable effectiveness of large language models in zero-shot semantic annotation of legal texts. *Front. Artif. Intell.* **2023**, *6*, 1279794. [CrossRef]
11. Weller, O.; Chang, B.; MacAvaney, S.; Lo, K.; Cohan, A.; Van Durme, B.; Lawrie, D.; Soldaini, L. FollowIR: Evaluating and teaching information retrieval models to follow instructions. *arXiv* **2024**, arXiv:2403.15246.
12. Azeem, M. I.; Abualhaija, S. A multi-solution study on GDPR AI-enabled completeness checking of DPAs. *Empir. Softw. Eng.* **2024**, *29*, 96. [CrossRef]
13. Priyanshu, A.; Vijay, S.; Kumar, A.; Naidu, R.; Mireshghallah, F. Are chatbots ready for privacy-sensitive applications? An investigation into input regurgitation and prompt-induced sanitization. *arXiv* **2023**, arXiv:2305.15008.
14. Nayak, S.P.; Pasumarthi, S.; Rajagopal, B.; Verma, A.K. GDPR Compliant ChatGPT Playground. In Proceedings of the 2024 International Conference on Emerging Technologies in Computer Science for Interdisciplinary Applications (ICETCS), Bengaluru, India, 25–26 April 2024; pp. 1–6.
15. Montagna, S.; Ferretti, S.; Klopfenstein, L.C.; Florio, A.; Pengo, M.F. Data decentralization of LLM-based chatbot systems in chronic disease self-management. In Proceedings of the 2023 ACM Conference on Information Technology for Social Good, Lisbon, Portugal, 6–8 September 2023; pp. 205–212.
16. Fei, Z.; Shen, X.; Zhu, D.; Zhou, F.; Han, Z.; Zhang, S.; Chen, K.; Shen, Z.; Ge, J. Lawbench: Benchmarking legal knowledge of large language models. *arXiv* **2023**, arXiv:2309.16289.
17. Guha, N.; Nyarko, J.; Ho, D.; Ré, C.; Chilton, A.; Chohlas-Wood, A.; Peters, A.; Waldon, B.; Rockmore, D.; Zambrano, D.; et al. Legalbench: A collaboratively built benchmark for measuring legal reasoning in large language models. In Proceedings of the 2023 Conference on Neural Information Processing Systems (NeurIPS 2023), New Orleans, LA, USA, 10–16 December 2023.

18. Dai, Y.; Feng, D.; Huang, J.; Jia, H.; Xie, Q.; Zhang, Y.; Han, W.; Tian, W.; Wang, H. LAiW: A Chinese legal large language models benchmark (a technical report). *arXiv* **2023**, arXiv:2310.05620.
19. Lai, J.; Gan, W.; Wu, J.; Qi, Z.; Yu, P. S. Large language models in law: A survey. *AI Open* **2024**, *5*, 181–196. [CrossRef]
20. Achiam, J.; Adler, S.; Agarwal, S.; Ahmad, L.; Akkaya, I.; Aleman, F.L.; Almeida, D.; Altenschmidt, J.; Altman, S.; Anadkat, S.; et al. GPT-4 technical report. *arXiv* **2023**, arXiv:2303.08774.
21. Petroni, F.; Rocktäschel, T.; Riedel, S.; Lewis, P.; Bakhtin, A.; Wu, Y.; Miller, A. Language models as knowledge bases? In Proceedings of the 2019 Conference on Empirical Methods in Natural Language Processing and the 9th International Joint Conference on Natural Language Processing (EMNLP-IJCNLP), Hong Kong, China, 3–7 November 2019; pp. 2463–2473.
22. Wei, J.; Bosma, M.; Zhao, V. Y.; Guu, K.; Yu, A. W.; Lester, B.; Du, N.; Dai, A. M.; Le, Q. V. Finetuned language models are zero-shot learners. *arXiv* **2021**, arXiv:2109.01652.
23. Apache Software Foundation. Apache License, Version 2.0. Available online: https://www.apache.org/licenses/LICENSE-2.0 (accessed on 18 November 2024).
24. Massachusetts Institute of Technology. MIT License. Available online: https://opensource.org/licenses/MIT (accessed on 18 November 2024).
25. Fourrier, C.; Habib, N.; Lozovskaya, A.; Szafer, K.; Wolf, T. Open LLM Leaderboard v2. Available online: https://huggingface.co/spaces/open-llm-leaderboard/open_llm_leaderboard (accessed on 18 November 2024).
26. Zhou, J.; Lu, T.; Mishra, S.; Brahma, S.; Basu, S.; Luan, Y.; Zhou, D.; Hou, L. Instruction-following evaluation for large language models. *arXiv* **2023**, arXiv:2311.07911.
27. Suzgun, M.; Scales, N.; Schärli, N.; Gehrmann, S.; Tay, Y.; Chung, H.W.; Chowdhery, A.; Le, Q.V.; Chi, E.H.; Zhou, D.; et al. Challenging big-bench tasks and whether chain-of-thought can solve them. *arXiv* **2022**, arXiv:2210.09261.
28. Rein, D.; Hou, B.L.; Stickland, A.C.; Petty, J.; Pang, R.Y.; Dirani, J.; Michael, J.; Bowman, S.R. GPQA: A graduate-level google-proof Q&A benchmark. *arXiv* **2023**, arXiv:2311.12022.
29. Sprague, Z.; Ye, X.; Bostrom, K.; Chaudhuri, S.; Durrett, G. MUSR: Testing the limits of chain-of-thought with multistep soft reasoning. *arXiv* **2023**, arXiv:2310.16049.
30. Wang, Y.; Ma, X.; Zhang, G.; Ni, Y.; Chandra, A.; Guo, S.; Ren, W.; Arulraj, A.; He, X.; Jiang, Z.; et al. MMLU-Pro: A more robust and challenging multi-task language understanding benchmark. *arXiv* **2024**, arXiv:2406.01574.
31. Yang, A.; Yang, B.; Hui, B.; Zheng, B.; Yu, B.; Zhou, C.; Li, C.; Li, C.; Liu, D.; Huang, F.; et al. Qwen2 technical report. *arXiv* **2024**, arXiv:2407.10671.
32. AI@Meta. Llama 3 Model Card. Available online: https://github.com/meta-llama/llama3/blob/main/MODEL_CARD.md (accessed on 18 November 2024).
33. Tunstall, L.; Beeching, E.; Lambert, N.; Rajani, N.; Rasul, K.; Belkada, Y.; Huang, S.; von Werra, L.; Fourrier, C.; Habib, N.; et al. Zephyr: Direct distillation of lm alignment. *arXiv* **2023**, arXiv:2310.16944.
34. Ding, N.; Chen, Y.; Xu, B.; Qin, Y.; Zheng, Z.; Hu, S.; Liu, Z.; Sun, M.; Zhou, B. Enhancing Chat Language Models by Scaling High-quality Instructional Conversations. *arXiv* **2023**, arXiv:2305.14233.
35. Mathur, P. orca_mini_v7_7b. Available online: https://huggingface.co/pankajmathur/orca_mini_v7_7b (accessed on 18 November 2024).
36. Mitra, A.; Del Corro, L.; Mahajan, S.; Codas, A.; Simoes, C.; Agarwal, S.; Chen, X.; Razdaibiedina, A.; Jones, E.; Aggarwal, K.; et al. Orca 2: Teaching small language models how to reason. *arXiv* **2023**, arXiv:2311.11045.
37. Liu, P.; Yuan, W.; Fu, J.; Jiang, Z.; Hayashi, H.; Neubig, G. Pre-train, prompt, and predict: A systematic survey of prompting methods in natural language processing. *Acm Comput. Surv.* **2023**, *55*, 1–35. [CrossRef]
38. von Schwerin, M. GitHub Repository: Llms-In-Gdpr-Documentation. Available online: https://github.com/magdalenavonschwerin/llms-in-gdpr-documentation (accessed on 18 November 2024).
39. Sokolova, M.; Japkowicz, N.; Szpakowicz, S. Beyond accuracy, F-score, and ROC: A family of discriminant measures for performance evaluation. In *Advances in Artificial Intelligence, Proceedings of the AI 2006, Hobart, Australia, 4–8 December 2006*; Sattar, A., Kang, B., Eds.; Springer: Berlin/Heidelberg, Germany, 2006; pp. 1015–1021.
40. Bukaty, P. *The California Consumer Privacy Act (CCPA): An Implementation Guide*; IT Governance Publishing: Ely, UK, 2019. Available online: http://www.jstor.org/stable/j.ctvjghvnn (accessed on 18 November 2024).